

Active Information Gathering & Scanning

Module 2 — Reconnaissance · Unit 08

Last week we *read* about the target. This week we start *talking to it* — and that changes everything legally.

Learning objectives

By the end of this unit you can:

- **Explain** active recon and why it legally requires authorization.
- **Describe** host discovery and port states: **open**, **closed**, **filtered**.
- **Run** an nmap ping scan (`-sn`) and read which hosts are up.
- **Distinguish** TCP connect (`-sT`) from SYN (`-sS`) scans.
- **Select** ports with `-p`, ranges, `-p-`, `--top-ports`.
- **Fingerprint** with `-sV`, `-O`, `-sC`.
- **Adjust** timing (`-T0`–`-T5`) and save output (`-oN`, `-oG`, `-oX`).
- **Grab a banner** with netcat and read what it reveals.

Ports: the doors of a host

- A **port** is a numbered door where a service listens (80 = web, 22 = SSH, 445 = SMB).
- **Host discovery** finds which machines are alive *before* checking their ports.
- Three port states:

State	Meaning
Open	A service is listening
Closed	Reachable, but nothing listening
Filtered	A firewall is blocking/dropping

Host discovery with nmap

```
sudo nmap -sn 192.168.56.0/24
```

- `-sn` = **ping scan**: find live hosts only, **no ports scanned yet**.
- Identify which IP is your target (the isolated lab VM).
- Find your own IP and subnet first:

```
ip a
```

Like finding which houses are occupied — before checking which doors are unlocked.

-sT **VS** **-sS**

```
nmap -sT --top-ports 20 <target-ip>    # TCP connect
sudo nmap -sS <target-ip>              # SYN / half-open
```

	-sT connect	-sS SYN
Handshake	Full 3-way	Half-open (SYN, then RST)
Root needed?	No	Yes
Profile	Noisier, logged	Faster, stealthier

Use **-sT** when you don't have root; **-sS** when you do and want speed/stealth.

Choosing ports

```
nmap -p 22,80,443 <target-ip>      # specific ports
nmap -p 1-1000 <target-ip>         # a range
sudo nmap -p- <target-ip>          # all 65535 (slower)
nmap --top-ports 20 <target-ip>    # most common
```

- Start small and broaden as you learn the target.
- `-p-` is thorough but slow — save it for when it's worth the wait.

Fingerprinting: what's behind the door?

```
sudo nmap -sS -sV -sC -O -p- <target-ip>
```

- `-sV` — **service & version** detection.
- `-O` — **OS detection** (a *guess*, not fact).
- `-sC` — nmap's safe **default scripts**.
- Star (★) the **version numbers** — they map to known vulnerabilities (Unit 09).

An open port says a door exists. Versions tell you exactly what's behind it.

Timing & output formats

```
sudo nmap -sS -sV -T4 -oA scan_target <target-ip>  
nmap -sT -T1 --top-ports 10 <target-ip>    # slow / stealthy
```

- Timing `-T0`–`-T5`: `-T4` is typical in lab; `-T0/-T1` evade detection but are slow.
- Output: `-oN` normal · `-oG` grepable · `-oX` XML · `-oA` all.
- `.gnmap` to **grep** open ports; `.xml` to **feed other tools**; `.nmap` to read.

Professionals save scan output as **evidence** for the report.

Banner grabbing with netcat

```
nc <target-ip> 21      # FTP banner  
nc <target-ip> 22      # SSH banner
```

- A **banner** is the text a service announces — often its name and version.
- Confirm nmap's `-sV` guess **by hand**.
- Example: FTP may announce `220 (vsFTPd 2.3.4)` — a famous lead. **Note it, do not exploit it.**

Ethics & Authorization

This unit sends packets to a target. That is direct-access territory.

Port-scanning a system you don't own or aren't authorized to test **can itself be a crime** — or evidence of attempted intrusion — even if nothing breaks.

No "just curious" exception

- The **same nmap command** is legal against our lab VM and a **crime** against a stranger's server. The only difference is **written authorization + defined scope**.
- Our scope: the isolated **Metasploitable 2** VM and approved **TryHackMe** rooms. Nothing else.
- nmap ships on every Kali box — **never** point it at the school network or the internet.

Discussion: knocking on every door to see which are unlocked isn't "breaking in." Is it harmless? Why does the law still care?

Key vocabulary

Term	Meaning
Active recon	Directly probing a target — needs authorization
Host discovery	Finding which hosts are alive
Port	A numbered door where a service listens
Port state	open / closed / filtered
nmap	The standard network mapper / port scanner
<code>-sn</code>	Ping scan (host discovery only)
<code>-sT</code> / <code>-sS</code>	TCP connect / SYN (half-open) scan
<code>-sV</code> / <code>-O</code> / <code>-sC</code>	Version / OS / default-script detection
Banner grabbing	Reading the text a service announces



Lab launch

Scanning an Isolated Target with nmap

Platform: Kali VM + **Metasploitable 2** on a **host-only** network. A TryHackMe "**Nmap**" room is an approved browser alternative.

Before any packet: confirm both VMs are host-only and write your scope statement.

Lab roadmap

- **A** — host discovery (`-sn`).
- **B** — progressive port scans (`-sT` / `-sS`, `-p`, `-p-`, `--top-ports`).
- **C** — fingerprinting (`-sV`, `-O`, `-sC`) — ★ the versions.
- **D** — timing + saved output formats (`-oA`).
- **E** — banner grabbing with netcat; compare to `-sV`.
- **Deliverable:** an **annotated scan results** journal entry + saved output files.

Recap

- Active recon **touches the target** — authorization is mandatory.
- Host discovery first (`-sn`), then ports, then fingerprinting.
- Port states: open / closed / **filtered** (firewall) $\neq$ closed.
- `-sT` (no root, noisy) vs `-sS` (root, stealthy). `-0` is a *guess*.
- Versions are the gold — they become Unit 09's vuln leads.
- Save output as evidence. Stay on the lab VM.

Exit ticket & discussion

Exit ticket: Why is the exact same nmap command legal against our lab VM but a potential crime against a stranger's server? Use *authorization* and *scope*.

Discuss: When would you choose `-sT` over `-sS`?

Next up — Unit 09: Vulnerability Scanning & Enumeration (and the Module 2 recon mini-project).